

# Klausur / Exam

## Grundlagen der IT-Sicherheit /

## Foundations of IT Security

H T  
W I  
G N

Prof. Dr. Hanno Langweg

2024-01-29T1130 – 2024-01-29T1300

- 15 Blätter einschließlich Deckblatt / *15 pages including this front page*
- Bearbeitungsdauer: **90 Minuten** / *Available time 90 minutes*
- Zugelassene Hilfsmittel: Keine  
*No permitted examination aids*
- Schreiben Sie Ihre Matrikelnummer auf **jede** Seite  
*Write your student number on **each** page*
- Benutzen Sie nur das Klausurpapier (Rückseite, wenn nötig)  
*Use only paper handed out (use reverse side of page if necessary)*
- Schreiben Sie **lesbar**. Verwenden Sie einen schwarzen oder blauen Stift, keinen roten oder grünen.  
*Write legibly. Use a black or a blue pen, do not use a red or a green one.*

Vorname: \_\_\_\_\_  
*Given name*

NACHNAME: \_\_\_\_\_  
*Family name*

Matrikelnr.: \_\_\_\_\_  
*Student number*

☐

AIN

☐

WIN

☐

Anderer Studiengang  
*(other)*

Regelmäßige Teilnahme an der Lehrveranstaltung in diesem Semester: ☐ ja ☐ nein  
*I attended classes regularly during the semester: yes no*

Allen, die gelernt  
haben, wünsche ich  
viel Erfolg und allen  
anderen viel Glück!

*Good luck!*

1. IT-Grundschutz / IT Base Protection (2 + 2 + 2 = 6)
2. Risikobewertung / Risk Assessment (2 + 2 = 4)
3. Schwachstellen / Vulnerabilities (2 + 2 = 4)
4. Malware (2 + 6 = 8)
5. Zugriffssteuerung / Access Control (2 + 2 + 4 = 8)
6. Positivlisten / Whitelisting (6 + 2 + 4 + 3 = 15)
7. Lieferketten / Supply Chains (6)
8. Statische Codeanalyse / Static Code Analysis (4)
9. Microsoft SDL (10)
10. Zertifizierung / Certification (6 + 2 + 8 = 16)
11. Kryptographie / Cryptography (2+1+1+1+1+2+1 = 9)

**1. IT-Grundschutz / IT Base Protection (2 + 2 + 2 = 6)**

Erklären Sie den Unterschied zwischen Basis-Absicherung, Kern-Absicherung und Standard-Absicherung nach IT-Grundschutz.

*Explain the difference between basic protection, core protection, and standard protection according to IT-Grundschutz.*

---

---

---

---

---

---

---

---

---

---

**2. Risikobewertung / Risk Assessment (2 + 2 = 4)**

Was sind die zwei Variablen in der Risikobewertung? Was macht die Bewertung einfacher oder schwerer bezogen auf die beiden Variablen?

*What are the two variables in risk assessment? What makes the assessment easier or harder with respect to these two variables?*

---

---

---

---

---

---

---

---

---

---

### 3. Schwachstellen / Vulnerabilities (2 + 2 = 4)

- a) Welchen Nutzen haben Datenbanken mit Daten über Softwareschwachstellen für den IT-Betrieb (z.B. die NVD National Vulnerability Database)?

*What is the benefit in IT operations of using a database containing data about known software vulnerabilities (e.g. the NVD National Vulnerability Database)?*

---

---

---

---

---

- b) Wozu dienen CVE-Bezeichner?

*What is the purpose of CVE identifiers?*

---

---

---

---

---

#### 4. Malware (2 + 6 = 8)

- a) Beschreiben Sie Ransomware mit Bezug auf Verbreitungsmethode und Schadfunktionalität.

*Describe ransomware with respect to propagation and payload.*

---

---

---

---

---

---

---

- b) Beschreiben Sie die drei üblichen Verfahren, wie Virens Scanner Malware erkennen und vergleichen Sie die Verfahren zusätzlich in den Dimensionen Genauigkeit, Geschwindigkeit und Effizienz.

*Describe the three common approaches how virus scanners detect malware and in addition discuss the approaches in terms of accuracy, speed, and efficiency.*

---

---

---

---

---

---

---

---

---

---

**5. Zugriffssteuerung / Access Control (2 + 2 + 4 = 8)**

- a) Erläutern Sie den Unterschied zwischen Zugriffssteuerung im freien Ermessen (DAC) und attribut-basierter Zugriffssteuerung (ABAC).

*Explain the difference between discretionary access control (DAC) and attribute-based access control (ABAC).*

---

---

---

---

---

---

---

- b) Benutzerrechte in Windows

*Privileges in Windows*

Nennen Sie zwei systemweite Benutzerrechte (Privilegien), welche es bei Zuweisung einem Benutzerkonto ermöglichen, die Zugriffssteuerung mittels Zugriffssteuerungslisten (ACLs) zu umgehen. Begründen Sie Ihre Wahl.

*Name two system-wide privileges that when assigned enable a user account to circumvent access control with access control lists (ACLs). Justify your choice.*

---

---

---

---

---

---

---

c) Inhalt von Strukturen der Zugriffssteuerung

*Content of structures in access control*

Gegeben sei folgende Zugriffssteuerungsmatrix:

*Consider the following access matrix:*

|          | WhatsApp | DB Navigator | Tagesschau.de | Wetter.com |
|----------|----------|--------------|---------------|------------|
| Contacts | RW       | R            |               |            |
| Location | R        | R            |               | R          |
| Music    | RW       |              | RW            |            |
| Pictures | RW       |              |               |            |

Schreiben Sie alle nichtleeren Zugriffssteuerungslisten auf.

*Write down all nonempty access control lists.*

---



---



---



---

Schreiben Sie alle nichtleeren Fähigkeitslisten auf.

*Write down all nonempty capability lists.*

---



---



---



---

**6. Positivlisten / Whitelisting (6 + 2 + 4 + 3 = 15)**

- a) Nennen Sie drei Arten, auf die Sie festlegen können, welche Dateien in eine WDAC-Positivliste aufgenommen werden. Geben Sie für jede der drei Arten Vor- und Nachteile an.

*Name three ways to specify which files are included in an application whitelist for WDAC. State advantages and disadvantages for each of the three ways.*

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

---

- b) Wozu dient der Audit Mode bei WDAC?

*What is the purpose of the audit mode of WDAC?*

---

---

---

---

---

---

---

---

c) Windows Defender Application Control (WDAC)

Kreuzen Sie alle richtigen und nur die richtigen Antworten an.

*Mark all correct answers and only correct answers.*

- ☐ Eine pfadbasierte Positivliste in WDAC gibt an, in welchen Verzeichnissen eine Anwendung Daten lesen darf.  
*A path-based application whitelist in WDAC specifies to which directories an application is allowed to read.*
- ☐ Eine pfadbasierte Positivliste in WDAC gibt an, in welchen Verzeichnissen eine Anwendung Daten schreiben darf.  
*A path-based application whitelist in WDAC specifies to which directories an application is allowed to write.*
- ☐ Eine pfadbasierte Positivliste in WDAC gibt an, in welchen Verzeichnissen Dateien ausgeführt werden dürfen.  
*A path-based application whitelist in WDAC specifies in which directories files are allowed to be executed.*
- ☐ Eine Positivliste in WDAC wird auf gewöhnliche Benutzerkonten angewendet.  
*An application whitelist in WDAC is applied to ordinary user accounts.*
- ☐ Eine Positivliste in WDAC wird auf Benutzerkonten von Systemadministratoren angewendet.  
*An application whitelist in WDAC is applied to user accounts of system administrators.*
- ☐ Eine pfadbasierte Positivliste in WDAC nennt man Fähigkeitsliste.  
*A path-based application whitelist in WDAC is called a capability list.*
- ☐ Eine pfadbasierte Positivliste in WDAC kann mit einer zertifikatbasierten Positivliste kombiniert werden.  
*A path-based application whitelist in WDAC can be combined with a certificate-based application whitelist.*
- ☐ Eine Positivliste in WDAC wird als Restricted SID in einem Token gespeichert.  
*An application whitelist in WDAC is stored as a restricted SID in a token.*

d) Was müssen Sie bei der Definition einer Positivliste für einen PC-Pool in einem Informatik-Studiengang beachten?

*What do you have to take into account when specifying an application whitelist for a computer lab in a computer science study programme at a university?*

---

---

---

---

---

---

---



### **8. Statische Codeanalyse / Static Code Analysis (4)**

Erläutern Sie die Begriffe „True Positive“, „False Positive“, „True Negative“, „False Negative“ mit Bezug zu statischer Codeanalyse.

*Explain the terms “true positive”, “false positive”, “true negative”, “false negative” related to static code analysis.*

---

---

---

---

---

---

---

---

---

---

---

---

## 9. Microsoft SDL (10)

Wählen Sie fünf Praktiken aus Microsofts SDL und erklären Sie diese.

*Pick five practices of Microsoft's SDL and explain them.*

[illegible]

**10. Zertifizierung / Certification (6 + 2 + 8 = 16)**

Die Foobar-Software der ACME Corp. hat eine EAL4-Evaluierung nach Common Criteria erfolgreich abgeschlossen.

*The Foobar software of ACME Corp. was successfully evaluated at EAL4 according to the Common Criteria product evaluation scheme.*

- a) Welche Rolle spielen die Anforderungen an die Einsatzumgebung eines TOE?  
*What is the role of the objectives for the environment of a TOE?*

---

---

---

---

---

- b) Was sind Tätigkeiten einer Evaluatorin für die genannten EALs, die nicht bereits für niedrigere EALs verpflichtend sind?  
*What are specific activities performed by an evaluator at the given EAL that are not mandatory for the lower EALs?*

EAL2 (zusätzlich zu / *added activities compared to* EAL1)

---

---

---

EAL3 (zusätzlich zu / *added activities compared to* EAL2)

---

---

---

EAL4 (zusätzlich zu / *added activities compared to* EAL3)

---

---

---

- c) Erläutern Sie das Vorgehen bei der Schwachstellenanalyse AVA\_VAN nach Common Criteria.  
*Explain how a vulnerability analysis AVA\_VAN is performed according to Common Criteria.*

---

---

---

---

---

---

---

---

---

**11. Kryptographie / Cryptography (2+1+1+1+1+2+1 = 9)**

- a) Was sind symmetrische und asymmetrische Verschlüsselungsverfahren?  
*What are symmetric and asymmetric cryptosystems?*

---

---

---

---

- b) Erläutern Sie ein hybrides Verschlüsselungsverfahren.  
*Explain a hybrid cryptosystem.*

---

---

---

---

- c) Warum ist die Länge eines kryptographischen Schlüssels wichtig?  
*Why is the length of a cryptographic key important?*

---

---

---

- d) Welche minimale Länge wird heutzutage für RSA-Schlüssel empfohlen?  
*What is the recommended minimum length for RSA keys?*

---

---

- e) Wo finden Sie verlässliche Informationen über empfohlene Schlüssellängen?  
*Where do you find reliable information about recommended key lengths?*

---

---

---

- f) Der One-Time-Pad ist der sicherste Verschlüsselungsalgorithmus. Warum werden in der Praxis meist weniger sichere Algorithmen verwendet?  
*The One-Time-Pad is the most secure encryption algorithm. Why are often less secure algorithms used in practice?*

---

---

---

---

---

---

- g) Wofür werden Zufallszahlen in der Kryptographie verwendet?  
*What is the purpose of random numbers in cryptography?*

---

---

---

---

---